

# Cybersecurity Awareness Report – Task 1

## 1. Executive Summary

Cybersecurity is not only about blocking hackers. It is about protecting the systems and information that a business depends on, understanding how those systems can fail, and reducing the impact when controls are bypassed.

This report covers the core security principles required for Task 1 and uses the 2017 Equifax breach as a practical case study.

The case demonstrates how an Internet-facing software vulnerability, weak patch-management execution, poor credential protection, insufficient network segmentation and monitoring gaps can combine into a much larger security incident. It also shows why analysts should distinguish documented facts from assumptions when reconstructing an attack.

## 2. Objectives

This task was completed to:

- Understand the CIA Triad.
- Distinguish threats, vulnerabilities, exploits and risk.
- Understand basic threat modeling.
- Learn the purpose of MITRE ATT&CK.
- Identify common attack vectors and social-engineering risks.
- Analyze a publicly documented breach.
- Translate technical lessons into defensive recommendations.

## 3. CIA Triad

### Confidentiality

Confidentiality protects information from unauthorized disclosure.

### Integrity

Integrity protects information and systems from unauthorized modification.

### Availability

Availability ensures authorized users can access systems and information when required.

### Application to Equifax

The strongest documented impact was confidentiality loss because sensitive personal information of approximately 147 million people was exposed.

The sources reviewed do not establish broad unauthorized modification of consumer records as the primary impact, so integrity should not be overstated.

Availability was not the main attacker objective; the incident focused on unauthorized access and data theft.

## 4. Threat, Vulnerability, Exploit and Risk

A threat is a potential cause of harm.

A vulnerability is a weakness that could be exploited.

An exploit is the method used to take advantage of a vulnerability.

Risk considers the likelihood and potential impact of a harmful event.

The relationship can be represented as:

Threat → Vulnerability → Exploit/Abuse → Incident → Impact

## 5. Threat Modeling

Threat modeling asks what can be attacked, how it could be attacked, what could happen after compromise, and which controls can reduce the risk.

A basic workflow is:

1. Identify assets.
2. Identify entry points.
3. Identify trust boundaries.
4. Identify threats.
5. Identify weaknesses.
6. Estimate impact and likelihood.
7. Select controls.
8. Reassess.

The Equifax case shows why the model must include the blast radius after an initial compromise.

## 6. MITRE ATT&CK

MITRE ATT&CK provides a structured knowledge base of adversary tactics and techniques.

For the Equifax case, **T1190 – Exploit Public-Facing Application** is the clearest technique mapping because the documented initial access involved exploitation of an Internet-facing vulnerable application.

I deliberately avoid assigning additional techniques where the public evidence reviewed is not strong enough. This is an important analyst habit: **do not turn assumptions into findings**.

## 7. Equifax Case Study

### Attack Vector

The attackers exploited CVE-2017-5638, a critical Apache Struts vulnerability, through the affected Internet-facing application.

NIST's NVD describes the vulnerability as allowing remote attackers to execute arbitrary commands through crafted HTTP headers and rates it 9.8 Critical under CVSS v3.1.

### Patch Management

The FTC complaint states that US-CERT alerted Equifax about the vulnerability in March 2017 and that Equifax's security team instructed responsible employees to patch affected systems within 48 hours.

The FTC later alleged that Equifax's vulnerability scan failed to detect the vulnerable software on the relevant ACIS system. This is an important process lesson: vulnerability management requires verification, not just a patching instruction.

### Post-Compromise Access

According to the FTC, attackers gained access to an unsecured file containing administrative credentials stored in plain text. Those credentials enabled access to large amounts of consumer information.

The FTC also alleged insufficient network segmentation and other basic security weaknesses.

### Impact

The FTC reported that approximately 147 million people were affected, including exposure of names, dates of birth and Social Security numbers. It also reported approximately 209,000 exposed payment-card numbers and expiration dates.

## 8. Root Causes

### Technical

- Unpatched Internet-facing software
- Plain-text administrative credentials
- Insufficient network segmentation
- Insufficient monitoring protections

## Process

- Patch-management execution failure
- Inadequate verification
- Incomplete vulnerability scanning
- Weak credential-management practices

## 9. Analyst Reasoning and Evidence Discipline

A professional breach analysis should separate what is documented from what is inferred.

### Confirmed findings from the sources reviewed

- CVE-2017-5638 affected the Apache Struts component.
- Equifax was alerted to the vulnerability.
- The vulnerable system was not successfully patched.
- Attackers exploited the vulnerable application.
- Administrative credentials were stored in plain text.
- Those credentials were used to access large amounts of consumer information.
- Network segmentation and intrusion-detection protections were inadequate.

### Reasonable defensive inference

The incident demonstrates that an Internet-facing application should have minimal access to sensitive systems and databases. It also demonstrates why credentials used by applications should be protected and tightly scoped.

### Claims we should not make without additional evidence

This report does not claim:

- the exact commands used by the attackers,
- the complete attacker infrastructure,
- broad modification of consumer records,
- or a complete ATT&CK attack chain beyond the evidence reviewed.

This evidence discipline is important in SOC, CTI and incident-response work.

## 9. Recommended Controls

### Prevent

- Maintain accurate asset inventory.
- Prioritize critical vulnerabilities on Internet-facing systems.
- Verify remediation after patching.
- Use secure secrets management.
- Apply least privilege.
- Segment sensitive systems.

## Detect

- Monitor Internet-facing applications.
- Correlate suspicious HTTP requests with server process behavior.
- Monitor access to sensitive databases.
- Alert on unusual administrative access.
- Monitor unusual outbound traffic.

## Contain

- Isolate compromised hosts.
- Revoke exposed credentials.
- Restrict network paths.
- Preserve forensic evidence.

## Recover

- Restore trusted systems.
- Rotate credentials.
- Validate patches and configuration.
- Conduct a post-incident review.

# 10. Detection Opportunities

The attack chain also provides a useful defensive detection model:

| Attack stage               | Observable                                       | Useful telemetry         |
|----------------------------|--------------------------------------------------|--------------------------|
| Public-facing exploitation | Suspicious HTTP requests                         | Web/WAF/application logs |
| Application abnormality    | Error spikes or unusual behavior                 | Application/server logs  |
| Post-exploitation          | Unexpected child processes                       | EDR/process telemetry    |
| Internal access            | Unexpected application-to-database connections   | Network/database logs    |
| Credential abuse           | Administrative credential use from unusual hosts | Authentication logs      |
| Data access                | Unusual database query volume                    | Database audit logs      |

| Attack stage          | Observable                                | Useful telemetry       |
|-----------------------|-------------------------------------------|------------------------|
| Possible exfiltration | Unexpected outbound connections/transfers | Firewall/proxy/NetFlow |

MITRE's current T1190 detection strategy uses a similar multi-signal approach: correlating suspicious requests with errors, post-exploitation process behavior and possible outbound activity.

A key lesson is that defenders should correlate multiple weak signals rather than relying on a single alert.

## 11. Security Awareness Lessons

The biggest lesson is that security failures are often connected.

A vulnerability becomes dangerous when it is exposed.

Exposure becomes more serious when patching fails.

A compromise becomes more damaging when the compromised application has excessive access.

The blast radius becomes much larger when sensitive credentials and databases are not adequately protected.

## 12. Final Reflection

This task changed the way I think about cybersecurity.

Before studying a real breach, it is tempting to think:

> "The attacker found a vulnerability and hacked the company."

The deeper explanation is more useful:

> A vulnerable entry point, a failure to verify remediation, weak internal controls and excessive access combined to turn one weakness into a major data breach.

That is the mindset I want to carry into the next tasks.

## 13. References

1. NIST Cybersecurity Glossary – Cybersecurity

<https://csrc.nist.gov/glossary/term/cybersecurity>

2. NIST – Information Security

[https://csrc.nist.gov/glossary/term/information\\_security](https://csrc.nist.gov/glossary/term/information_security)

3. NIST – CIA

[https://csrc.nist.gov/glossary/term/confidentiality\\_integrity\\_availability](https://csrc.nist.gov/glossary/term/confidentiality_integrity_availability)

4. NIST – Vulnerability

<https://csrc.nist.gov/glossary/term/vulnerability>

5. NIST NVD – CVE-2017-5638

<https://nvd.nist.gov/vuln/detail/CVE-2017-5638>

6. FTC – Equifax settlement and breach details

<https://www.ftc.gov/news-events/news/press-releases/2019/07/equifax-pay-575-million-part-settlement-ftc-cfpb-states-related-2017-data-breach>

7. FTC – Equifax complaint

[https://www.ftc.gov/system/files/documents/cases/172\\_3203\\_equifax\\_complaint\\_7-22-19.pdf](https://www.ftc.gov/system/files/documents/cases/172_3203_equifax_complaint_7-22-19.pdf)

8. MITRE ATT&CK

<https://attack.mitre.org/>

9. MITRE T1190 – Exploit Public-Facing Application

<https://attack.mitre.org/techniques/T1190/>

10. MITRE T1190 Detection Strategy

<https://attack.mitre.org/detectionstrategies/DET0080/>